Email Header Analyser

A single-page tool for checking raw email headers. Paste the headers from a message and it reports authentication results (SPF, DKIM, DMARC, ARC), spam-filter verdicts, signs of spoofing, and the route the message took to reach the inbox.

Everything runs in your browser. The headers you paste are never uploaded.

Usage

The whole tool is one self-contained file, `index.html`. It has no build step, no dependencies and needs no server.

- **Locally:** download or clone the repo and open `index.html` in a modern browser.
- **Hosted:** serve the file from any static host, such as GitHub Pages. A `<meta>` CSP can't set `frame-ancestors`, so configure the host to also send the HTTP header `Content-Security-Policy: frame-ancestors 'none'`. That stops other sites from embedding the page in a frame.

```
git clone https://github.com/Older-Statler/AnalyseHeader.git
cd AnalyseHeader
# then open index.html in your browser
```

Paste the headers into the text box. Analysis starts as soon as you paste. You can also click **Analyse** or press **Ctrl+Enter** (**Cmd+Enter** on macOS). To see example output, use **Load sample: legitimate** or **Load sample: suspicious**.

The tool reads at most 1 MB of input and 64 KB per header value. If anything is cut off, an "Input truncated" warning appears and the score goes down. From, Reply-To, Sender and `Authentication-Results` values over 64 KB are not parsed at all.

What it shows

- **Verdict and score.** An overall rating ("Looks legitimate", "Some concerns" or "Suspicious") and a score from 0 to 100. The score starts at 100 and loses points for each failed check or warning. These always give the "Suspicious" rating:
    - a DMARC failure
    - a display name that hides a different address, or that uses text-direction controls
    - a From header that is too long to parse

These give at most "Some concerns":

```
- no trusted authentication results (no top-level `Authentication-Results` header, or no
`Received` or `X-Received` header)
- a serious failed check, such as a DMARC, CompAuth, display-name or From-header failure, or a
Microsoft threat category like phishing or spoofing
```

When one of these rules lowers the verdict, the score is lowered to match: at most 79 for "Some concerns" and at most 49 for "Suspicious". The verdict card then shows "Score capped:" followed by the reason.

- **Authentication cards.** SPF, DKIM, DMARC and, when present, ARC and Microsoft CompAuth.
    - **Top-level results.** Results come only from the trusted `Authentication-Results` block, which the final receiving server adds. The block is the first `Authentication-Results` header plus any others with the same authserv-id that sit above the topmost server hop. A server hop is a `Received` or `X-Received` header. The panel notes that the results assume your receiving server added the topmost `Authentication-Results` header.
    - **No server hop, no trust.** If there is no `Received` or `X-Received` header at all, the results can't be attributed to your mail provider. Only the first `Authentication-Results` header is used, and its results are shown as "Unverified — may be sender-supplied".
    - **Other headers are ignored.** No other `Authentication-Results` headers are mixed in. If one reuses the receiver's ID, you get a "Possible forged Authentication-Results" warning. If it comes from another server, you get an info note.
    - **Earlier failures are reported.** A fail, softfail, hardfail or permerror in an ignored `Authentication-Results` header or in any ARC instance appears as an "An earlier server recorded ... fail" warning. A sender has no reason to forge a failure. Passes from these sources are never trusted.
    - **Fallbacks are unverified.** If there's no `Authentication-Results` header, the tool uses the highest-instance `ARC-Authentication-Results` that has a matching `ARC-Seal` with a `cv` other than `fail`. If there's still no SPF result, it uses `Received-SPF`. These fallback results are labelled "Unverified — may be sender-supplied" and don't count as passes.
- **Message summary.** From, Sender, Reply-To, Return-Path, To, Subject, Date, Message-ID, number of hops, total delivery time, originating IP and mailer. Encoded words (RFC 2047) are decoded. In address headers, the tool removes comments and then reads the email address from the raw value. Only the display name is decoded, so an encoded word or a comment can't fake the address.
- **Security checks.** Each check is marked Fail, Warn, Pass or Info, and you can filter the list by category. The checks cover:

- SPF and DKIM domain alignment with the From domain
- a DMARC result that applies to a different domain than From
- display-name spoofing: an address in the display name whose organisational domain differs from the From domain.
- **What counts as an address.** The domain must contain a dot, and its ending can be letters in any script (for example `.pф`). Subdomains of the From domain aren't flagged.
- **Contains.** Any `@domain` visible in the name as written gives "Display name contains a different address", whether or not there is a part before the `@`. That includes quoted addresses such as `"john smith"@example.com`. A social handle in a display name, such as `Ana @ana.dev`, may therefore cause a "Some concerns" warning. Phrases such as `Meet @ 10.30am` aren't flagged, because there's no domain ending made of letters.
- **Cleanup.** Before checking, the text is cleaned up:
- It is Unicode-normalised (NFKC), so full-width look-alikes such as `＜service@paypal.com＞` are caught.
- Invisible characters such as zero-width spaces and soft hyphens are removed.
- Dot look-alikes such as the ideographic full stop 。 are treated as dots.

The name is still displayed as written.

- **Hides.** These give "Display name hides a different address" and force "Suspicious":
- an address that only appears after decoding an encoded word, after cleanup, or inside a comment (no part before the `@` needed)
- a domain label that mixes alphabets, such as Latin with a Cyrillic letter in `paypal`
- an unusual space (non-breaking, thin, hair space and so on) or an invisible character directly before or after an `@`, or inside the domain

Domains in a single script, such as `.pф` or `müller.de`, are fine.

- text-direction controls in the From header: right-to-left override, embedding and isolate characters (U+202A–U+202E, U+2066–U+2069). These can make a reversed address look genuine, so they give "Display name uses text-direction controls" and force "Suspicious". Plain direction marks (LRM, RLM, ALM) are allowed, so normal Arabic and Hebrew names are unaffected.
- ambiguous From headers: more than one `<`, unbalanced quotes or comments, or an `@` outside the address and display name (for example in a comment)
- a Reply-To address that differs from From
- punycode (`xn--`) From domains
- DKIM signatures that use SHA-1 or have expired
- spam-filter verdicts (Microsoft SCL, SFV, CAT and BCL; SpamAssassin). Spam verdicts

count against the message. Clean verdicts are shown as info only, because senders can add these headers.
- external hops with no visible TLS
- a future-dated `Date` header and hop timestamps out of order
- slow hops and long delays before sending
- a missing `Message-ID` or `Date` header
- the sending software (bulk-mailer tools get a warning)
- bulk mail, detected by a `List-Unsubscribe` header
- **Mail flow.** A route strip from the sender to the inbox, plus a timeline with one entry per hop. Each entry shows:
- the HELO name, reverse DNS and receiving host
- the IP address, marked public or private
- TLS version and cipher, when the headers record them
- authenticated submission
- the delay since the previous hop
- the raw `Received` header
- **All headers.** A searchable table of every header. Security-relevant headers are highlighted, and encoded values are shown both decoded and raw.
- **Safe display of header text.** Everywhere the page shows header text, text-direction control characters appear as visible markers such as `[U+202E]`. Untrusted text is displayed in isolation, so it can't reorder the rest of the page.
- **Light/dark theme.** It follows your system setting by default. The toggle button overrides it, and your choice (`light` or `dark`) is saved in the browser's `localStorage`.

Privacy

All parsing and analysis happen inside the page, in JavaScript. A Content-Security-Policy in `index.html` (`default-src 'none'`) stops the page from making network requests or loading external resources. The only script allowed to run is the page's own inline script, which is identified by its hash. The CSP doesn't block navigation, such as following a link. All header text is escaped before it is displayed. Text-direction controls appear as visible `[U+…]` markers, so a crafted header can't reorder what you see.

The only outbound links are the optional **reputation** links next to public IP addresses in the mail-flow timeline. They point to AbuseIPDB and open in a new tab only when you click them. Clicking one sends that IP address to AbuseIPDB.

How to get raw headers

Email clients change their menus often, so these steps may not match your version exactly.

- **Gmail (web):** open the message, click the three-dot menu, then choose **Show original**.
- **Outlook (classic desktop):** open the message, then go to **File > Properties** and copy the **Internet headers** box.
- **Outlook (web / new Outlook):** open the message, click the three-dot menu, then choose **View > View message source** (or **View message details**).
- **Apple Mail:** choose **View > Message > All Headers** or **View > Message > Raw Source**.
- **Thunderbird:** choose **View > Message Source** (Ctrl+U / Cmd+U).

You can paste the full message source instead of just the headers. Parsing stops at the first blank line, where the body begins. A line counts as blank if it contains only whitespace: spaces, tabs, non-breaking spaces, vertical tabs, form feeds and similar characters. This covers webmail copies that turn the blank line into non-breaking spaces.

Unicode line and paragraph separators (U+2028, U+2029) are handled differently:

- A line containing only one of them doesn't count as blank.
- They don't split headers either; only ordinary line breaks do. A header line that contains one is kept whole.

Limitations

- **Nothing is cryptographically verified.** The tool doesn't check DKIM signatures or ARC seals, look up DNS (SPF, DKIM or DMARC records), or check IP reputation. It reports what the receiving server recorded.
- **Headers the sender could add are shown but not trusted.** Headers such as ignored `Authentication-Results`, `ARC-Authentication-Results`, `Received-SPF` and spam-filter verdicts can be written by the sender. The tool displays them, and reports any failures they record, but never treats them as evidence that a message is safe. It does trust the topmost `Authentication-Results` block, so its results are only as reliable as the headers you paste. Copy them straight from your own mail client.
- **Look-alike detection is partial.** The display-name cleanup handles full-width forms, invisible characters, common dot look-alikes, mixed alphabets and text-direction controls, but not every disguise. These aren't detected:
  - some dot look-alikes, such as ･ and ·
  - circled letters (such as Ⓐ)
  - spelled-out addresses (`service at paypal.com`)

    - names that only add text after the real domain (`service@paypal.com.evil.com`, when the From domain is `evil.com`)
- **Alignment is approximate.** To check alignment, the tool works out each domain's "organisational domain" (for example, `example.co.uk` for `mail.example.co.uk`). It uses a simple built-in rule for this, not the Public Suffix List, so some domains will be grouped incorrectly.
- **Partial headers give partial results.** If the pasted headers are incomplete, many results will show as "not found".
- **Heuristic checks.** TLS detection, internal/external hop classification and `Received` parsing rely on pattern matching. Unusual server formats may be misread.
- **The score is a guide, not a guarantee.** A high score doesn't prove a message is safe, and a low score doesn't prove it's malicious. Use the score together with your own judgement.

Contributing / editing the page

The Content-Security-Policy only allows the inline script whose SHA-256 hash it contains. **If you change anything in the `<script>` block, you must regenerate the hash.** Otherwise the browser will block the script and the page will do nothing. Run this command from the repo folder (it's also in a comment above the CSP `<meta>` tag):

```
node -e 'const
h=require("fs").readFileSync("index.html","utf8"),t="script>";console.log("sha256-"+require("c
rypto").createHash("sha256").update(h.slice(h.lastIndexOf("<"+t)
+t.length+1,h.lastIndexOf("</"+t))).digest("base64"))'
```

Then replace the `'sha256-…'` value in the `script-src` part of the CSP with the new output.

Project status

This is an early-stage project. A security review was carried out and its findings have been addressed in the code. No license has been chosen yet.

Source: README.md in github.com/Older-Statler/AnalyseHeader (branch main).